

Concepto de ventana de tiempo, desarrollo de estrategias de recuperación y alternativas de recuperación

Proceso de planeamiento de un BCP

1) Identificación de recursos

a) BIA – Business Impact Analysis (Análisis de impacto en el negocio)

En dicha etapa, se busca identificar los distintos eventos que pueden impactar sobre la continuidad de las operaciones. Lo que busca es armar supuestos para distintos escenarios de riesgos que puedan plantearse, tratando de comprender:

- Los distintos componentes de los riesgos.
- Describir las consecuencias.
- Identificar interrelaciones de procesos.

Entre las consideraciones a tener en cuenta aparecen:

- Qué puede suceder.
- Cuándo puede suceder.
- Cuánto puede durar.
- Si se puede repetir.
- Qué nivel de severidad puede tener.
- Cuál es el tiempo máximo de recuperación.
- Si existe algún tipo de efecto cascada (debe tenerse en cuenta que algunas amenazas pueden ocasionar efectos no deseados en otros recursos, por ejemplo: electricidad, agua, personal).

b) Actividades

Eventos

1. Identificación de los eventos que pueden incrementar los riesgos (operacional, riesgos de TI, riesgos de SI, CIA).
2. Consideraciones sobre el impacto.

3. Categorizar las amenazas.
4. Establecer matrices (Amenazas / Impacto & Amenaza / Efecto).

Procesos claves

- Agrupados en función de: costo, tiempo, imagen.
- Determinación de las funciones críticas.
- Debería evaluarse, valorarse y documentar el nivel de criticidad de cada función de acuerdo con el impacto operacional, comercial, económico, financiero y legal ante la interrupción.
 - Identificar unidades de negocio.
 - Identificar *owners*.
 - Definir impacto en la organización por falla en la unidad de negocio.
 - Definir el nivel crítico de las funciones de cada unidad de negocio.
 - Evaluar sus riesgos.
 - Evaluación por la alta gerencia.
 - Desarrollar y documentar junto al responsable de la unidad de negocio las acciones de contingencia para cada función crítica.

c) Determinación de Recursos Críticos (Aplicaciones Críticas)

Una aplicación crítica es un subconjunto del sistema de información total que es **vital** para la subsistencia de las operaciones del negocio.

- Establecer un esquema de clasificaciones de aplicaciones (se desarrolla a continuación).
- Obtener un inventario de aplicaciones.
- Clasificar las aplicaciones por *owners* (ayuda de SI y organización).
- Estimar los costos de una parada en un aplicativo.
- Determinar la **dependencia** entre aplicativos.
- Determinar **recursos** críticos para soportar a las aplicaciones.
- Validar el listado con los *owners* y alta gerencia.
- Analizar aplicativos no críticos.
- Documentar.

2) Tiempos o períodos de recuperación

Los dos conceptos vinculados son:

a) RTO – Tiempo objetivo de recuperación (Tolerancia del Servicio)

Es el tiempo en el cual deben reanudarse los procesos antes de incurrir en pérdidas; por lo tanto, deben analizarse:

- Cuáles son las funciones de negocio a recuperar en tiempo crítico.
- Aplicaciones a recuperar.
- Interrelación entre funciones de negocio, aplicaciones y procesos.
- Prioridades de recuperación.
- Dependencia del momento en el cual se manifiesta una contingencia; afecta directamente sobre el tiempo crítico de recuperación.

b) RPO – Punto Objetivo de recuperación (qué tan frescos son los datos)

Es posible referirse al RPO como a qué momento anterior a la contingencia se deben recuperar los datos y procesos. Algunos aspectos a tener en cuenta son:

- Funciones de negocios esporádicas pueden no verse afectadas.
- Aplicaciones que se relacionan con esto.
- Dependen del momento en que ocurran.
- Se relaciona con las prioridades de recuperación.

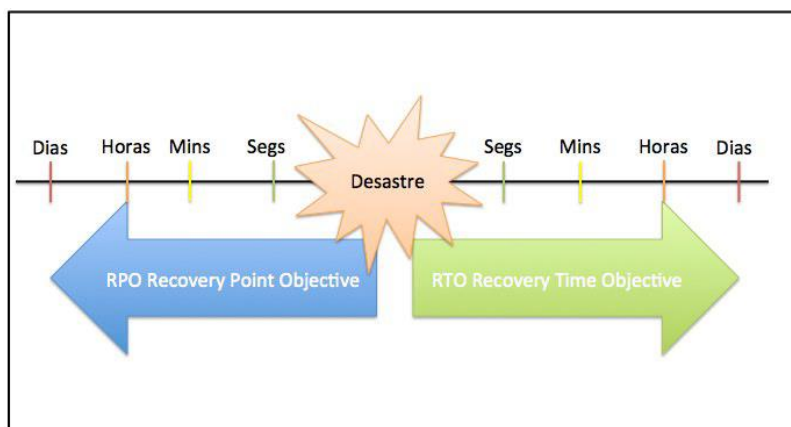


Figura 1: Tiempo o período de recuperación. Fuente: elaboración propia.

3) Clasificación de los Sistemas

Debe realizarse en función del riesgo / criticidad del aplicativo para el negocio. De manera general, los niveles de clasificación más utilizados son:

Crítico

Son aquellos sistemas en que sus funciones no pueden dejar de realizarse a menos que se consigan capacidades idénticas. Cuentan con muy baja tolerancia a las interrupciones. Por lo general, realizan gran cantidad de tareas automatizadas, no pudiendo ser reemplazadas por tareas manuales. Tolerancia baja, tiempo bajo, costo alto.

Vital

Son aquellos sistemas en que sus funciones pueden ser realizadas de manera manual, pero por un tiempo corto. Tolerancia, tiempo y costo medio.

Sensitivos

Son aquellos sistemas cuyas actividades pueden realizarse de manera manual a un costo tolerable por un tiempo prolongado. Por lo general, requieren de mayor personal para llevar adelante la tarea.

No crítico

Pueden ser interrumpidos por un tiempo significativo sin impactar considerablemente en la operatoria de la empresa. Por lo general, se requiere poco esfuerzo para ponerse al día de las tareas atrasadas.

Desarrollo de estrategias de recuperación / Continuidad (COOP + DRP)

Durante esta etapa se realiza la selección de la estrategia de recuperación más adecuada frente a la aparición de un desastre.

Criterios de selección

La selección de la estrategia de recuperación puede realizarse en función de distintos criterios:

- Criticidad del proceso para el negocio.
- Costo.
- Tiempo de recuperación.
- Nivel de confidencialidad de la información relacionada al proceso (seguridad).

Alternativas de recuperación

Frente a la caída del CPD pueden plantearse distintas alternativas de recuperación vía el procesamiento *off-site*.

Hot Site	Warm Site	Cold Site
Proveen o suministran una CONFIGURACION TOTAL y similar al sitio primario. En donde en un par de horas se está procesando en este nuevo centro. Poseen equipos y software compatibles con los utilizados en la empresa Como desventaja en su uso se presentan los COSTOS. Quizás esta opción se justifica frente a aplicaciones críticas. Por lo general, se utilizan en tiempos acotados de uso, ya que su costo lo hacen poco viable. Un tema a tener en cuenta son todas las configuraciones que deben tenerse en cuenta al definir los aspectos de conectividad de red.	Son sitios que se encuentran parcialmente configurados. Por lo general, sí está configurado lo periférico y no el esquema de procesamiento central. Algunas alternativas de este tipo de solución proveen el uso de equipos de menor capacidad de procesamiento. Podríamos decir que son equipos de simple obtención, frente a la aparición de una emergencia Uno de los puntos a tener en cuenta es el TIEMPO en que son posible tener operativos el centro de procesamiento.	Se encuentran inicialmente preparados Solo tienen a disposición aspectos físicos como: infraestructura edilicia básica, energía eléctrica, aire acondicionado, montaje de cableado.

Figura 2: Alternativas de recuperación. Fuente: elaboración propia.

Desarrollo de un plan detallado

Procedimientos de evacuación:

- Procedimientos de declaración de desastres y fin de desastres. Cuando salgo de un desastre: generalmente se da por terminado cuando se vuelve a procesar en el CPC principal nuevamente.
- Definición de recursos indispensables: el plan debe contener un directorio de notificación conteniendo: nombre, teléfono, direcciones del personal clave, lista priorizada de contactos, proveedores de equipos y servicios, personal contratado.
- Asignación de responsabilidades.
- Dependiendo del tamaño de las operaciones del negocio podrán designarse los siguientes **equipos o grupos**:
 - Acción ante emergencias.
 - Manejo de la emergencia.
 - Operaciones de emergencias

- Soporte administrativo.
- Salvamiento.
- Manejo de insumos y suministros requeridos.

Plan de pruebas

Existen distintos esquemas de pruebas a realizar para verificar el plan de recuperación. Si es posible, deben llevarse adelante pruebas integrales o totales, sino llevar adelante pruebas parciales.

El propósito de las pruebas es:

- Determinar qué tan bien trabaja el plan y qué partes del plan son necesarias mejorar.

Entre los aspectos a tener en cuenta se encuentran:

- Cuándo llevar adelante las pruebas.
- Evaluación del desempeño.
- Definición de las tareas a llevar adelante: **pre - durante - post** pruebas (eliminación de los datos, mejora en el procesamiento).

1) Tipos de pruebas

Existen distintos tipos de pruebas:

a) Pruebas en papel

Por lo general son pruebas de preparación, definiendo un recorrido general por el plan. Son también conocidas como pruebas de escritorios mediante el uso de *checklist*.

b) Pruebas parciales

Es una versión localizada, realizando una simulación parcial.

c) Pruebas operativas totales

Simula un operativo real de desastre... La pregunta es: “¿Cortamos o no?”

2) Resultados de las pruebas

Entre los resultados de las pruebas deben verificarse:

- a. Verificar que la información del plan es completa.
- b. Análisis de los tiempos requeridos.
- c. Evaluar el rendimiento del personal involucrado.
- d. Evaluar el entrenamiento del personal.
- e. Evaluar la coordinación entre equipos.
- f. Medir las capacidades de recupero de datos.
- g. Evaluar el estado de los materiales.
- h. Medición del rendimiento en general.

Documentación de los resultados

Se debe mantener información detallada e las observaciones de los problemas detectados y alternativas de resolución adoptadas. Debe realizarse un análisis detallado de los resultados obtenidos:

- Tiempos obtenidos.
- Cantidad y tipo de trabajo realizado.
- Conteo de revisiones de información requerida.
- Exactitud de los datos de entrada y salida.

Mantenimiento del plan de recuperación

Revisar y actualizar en forma programada los planes y estrategias para la continuidad del trabajo. Entre los aspectos a verificar se encuentran:

- Cambios en el negocio.
- Cambios en los sistemas.
- Programas de revisiones.
- Cambios en los roles.
- Comentarios y sugerencias.
- Cronogramas de entrenamientos.
- Registros de actividades.

Principales lecciones aprendidas

- La infraestructura necesita ser más distribuida geográficamente.
- Contar con un plan de continuidad y recuperación: asegurar que los recursos estén entrenados, desarrollo interno.
- Asegurar la portabilidad de los servicios y las personas: acceso remoto, documentación en web, etc.
- Proteger los equipos y servicios de misión crítica.
- Construir facilidades blindadas: analizar redes de comunicación y facilidades de ruteo.
- Repasar alternativas existentes, incluso la de *outsourcing*.

Auditoría del plan de contingencia

- Verificar que el plan de contingencia sea efectivo para asegurar el desarrollo de las capacidades mínimas para mantener la continuidad del negocio.
- Verificar que las actividades puedan ser reanudadas rápidamente luego de una interrupción imprevista.
- Si existe almacenamiento *off-site*, se debe evaluar por medio de revisiones:
 - Infraestructura.
 - Seguridad.
 - Controles ambientales.
 - Niveles de sincronización.
 - Niveles de actualización de los medios magnéticos.
 - Documentación crítica.
 - Se debe evaluar la habitualidad del personal de las distintas áreas para responder a situaciones de emergencia.
 - Nivel de entrenamiento.
 - Resultados de las pruebas.
 - Revisión de las coberturas de seguros, a fin de que estos reflejen el costo actual de la recuperación.
 - Revisión de la seguridad física y lógica de las sedes alternativas, idéntica a la sede primaria.
 - Revisión del contrato de la sede alternativa: cumplimiento de pautas y pruebas del plan.

- Contratos de provisión de equipos, servicios y tiempos de entrega.
- Documentación y manuales.
- Acuerdos de confidencialidad firmados por los distintos involucrados.
- Manejo de la publicidad y difusión.
- Relaciones jurídicas con las interfaces externas.

Referencias bibliográficas

- CISSP Sixth Edition – Shon Harris Mc Graw Hill.
- ISO 22301 Gestión de Continuidad de Negocio en la práctica (23 de julio de 2017). *ISOTOOLS*. Recuperado de <https://www.isotools.org/2017/07/23/iso-22301-gestion-continuidad-negocio-la-practica/>
- Piattini, M. y Del Paso, E. *Auditoría Informática: Un enfoque práctico* (Capítulo 15: “Auditoría de Técnica de Sistemas”).